ECHELON INSURANCE PRIVACY OFFICE · TRAINING GUIDE

Applying the Privacy Residual Risk Decision Rule

How to score a privacy risk so that anyone with the same facts reaches the same rating.

Rule v1.1 · Four inputs per risk

29 October 2026

What this guide covers

PART 1 · UNDERSTAND

Why we use a rule and where it sits

The problem it solves, and which steps of the PIA it covers.

PART 2 · ENTER

The six things you decide

Two settings for the PIA, four scores for each risk, and how to make each one well.

PART 3 · READ

What the workbook gives back

The calculation, two worked examples, the decision table and a checklist.

WHY WE USE A RULE

Same facts, same rating, whoever does the assessment.

Questionnaires give evidence, not ratings

An answer in a PIA questionnaire tells you what someone says is in place. The rating comes from what you can show.

The rule decides one step only

It fixes how inherent risk and controls combine into a residual rating. Scoping, risk identification and the approval table are unchanged.

Your judgment still matters

You still decide impact, likelihood, effectiveness and evidence. The rule only stops two analysts combining the same judgments differently.

Where the rule sits in the PIA process

The methodology has seven steps. The rule takes what you record in steps 3 and 4 and produces step 5. Steps 1, 2, 6 and 7 are unchanged.

1	2	3 · you score	4 · you score	5 · the rule	6	7
Confirm scope	**Identify risks**	**Assess inherent risk**	**Evaluate controls**	**Determine residual risk**	**Decide and approve**	**Monitor and reassess**
Purpose, data, people, flows	One row per distinct risk	Impact and likelihood	Effectiveness and evidence	Calculated, not judged	Treat, accept, avoid, escalate	On change or on cycle

Before step 3, resolve any open gates: a missing contract, a transfer assessment not done, a third-party due diligence not completed. A rating does not clear a gate.

PART 2 · ENTER

You enter six things. The workbook does the rest.

Once per PIA

- **Data class** — the most sensitive data in scope
- **Modifier** — scale or vulnerable group, if either applies

For each risk

- **Inherent impact** — 1 to 5
- **Inherent likelihood** — 1 to 5
- **Control effectiveness** — 1 to 5
- **Evidence status** — Supported, Partial, Not verified

You also name the control you relied on, from the catalogue. That is a record, not a score.

Calculated for you

- Inherent band
- Likelihood credit
- Residual likelihood and band
- ERM level
- PIA rating, signatory, review cycle

Before you score: write the risk clearly

Because [cause], [event] may occur, affecting [individuals] and causing [harm].

Example

Because the vendor stores payee bank account numbers and its support staff can access them, an unauthorized disclosure may occur, affecting claimants and causing financial fraud and identity harm.

Three rules

- One row per distinct risk
- Split a risk when the cause, the people affected, the control or the harm differs
- Score one gap once; if two rows share a gap, the rationale says which row carries it

PIA SETTING 1 OF 2

The data class sets the minimum impact

Most sensitive data in scope	Minimum inherent impact
Public or effectively de-identified information	1 Insignificant
Basic contact information, mostly business contact details	2 Minor
Ordinary personal information, policy and non-injury claims details	3 Moderate
Highly Confidential: banking, licence, SIN, health, injury claims, underwriting or credit decisions	4 Major
Identity-takeover combinations, biometrics, at-risk location data, criminal or immigration status, children’s data	5 Extreme

If you score a risk below the minimum, the sheet flags it. That is allowed when the harm is not exposure of that data (late deletion, an unclear notice, loss of control). Say so in the rationale.

PIA SETTING 2 OF 2

The modifier moves the band up one step

Scale

More than 10,000 individuals affected.

Count people, not records. If the questionnaire gives records, say what you assumed.

Vulnerable group

The people affected are mostly vulnerable: minors, claimants in crisis.

“Mostly” is the test. Some vulnerable people in a general population does not qualify.

How it applies

- Set once for the whole PIA
- One step only, even if both apply
- Low becomes Medium, Medium becomes High, High stays High
- Applied at the inherent stage and again at the residual stage

Scale and vulnerability describe the processing, not the controls, so good controls do not remove the modifier. A large Highly Confidential initiative therefore stays High at residual; the controls decide the action list, not the band.

INPUT 1 OF 4

Inherent impact: the worst credible harm to one person

Level	Harm to the most exposed person	Typical data
1 Insignificant	No discernible harm; trivial, immediately reversible inconvenience	Public or de-identified
2 Minor	Limited concern or short-lived loss of control; readily remedied	Basic contact details
3 Moderate	Material distress, financial inconvenience or loss of privacy; reversible with effort	Ordinary personal information
4 Major	Serious financial, identity, physical or discriminatory harm that is difficult to reverse	Banking, licence, SIN, health
5 Extreme	Catastrophic or widespread harm to safety, livelihood or fundamental rights	Identity-takeover sets, biometrics, children

Score before controls. “Credible” means a plausible outcome given the data, the recipients and realistic misuse, not a theoretical worst case. Organizational harm is recorded separately and never lowers the individual level.

INPUT 2 OF 4

Inherent likelihood: how likely without the controls

Level	Meaning	Signs you would see
1 Rare	Only in exceptional circumstances	Internal use, few users, few people affected
2 Unlikely	Could happen, not expected	Limited sharing, mature process
3 Possible	Might happen	Vendor involved, manual handling, new process
4 Likely	Will probably happen	Cross-border transfer, sub-processors, broad access, new use
5 Almost certain	Expected to happen	A known gap left open

Imagine the controls you are about to assess are not there. Count the signs in the right-hand column: two or three of the Likely signs together usually mean Likely. Controls earn their credit in the next two inputs, not here.

BETWEEN THE INPUTS

Name the weakest control you are relying on

1. **List the controls** that actually reduce this risk. Ignore controls that address a different risk.
2. **Pick the weakest one.** Where several work together, the weakest sets the credit for the whole set.
3. **Choose its name from the catalogue** in column F. Put the detail (which system, which vendor) in the rationale.

The pathway map checks your choice

- The control must be on the map for the risk category, or it earns no credit
- Governance controls (roles, policies, training, inventories, monitoring) support every risk but earn no credit alone
- A control typed by hand, outside the catalogue, earns no credit

Column K tells you which of these applies. A “No” there is a prompt to check the control you chose, not a reason to change the category.

INPUT 3 OF 4

Control effectiveness: design and operation

Level (Risk team scale)	What it looks like in practice	Can earn credit?
1 Fully effective	Designed for this pathway and operating as intended, with no known gaps or exceptions	Yes, up to 2
2 Mostly effective	Operating, with minor gaps that do not leave the pathway open	Yes, 1
3 Partially effective	Covers part of the pathway, or operates inconsistently; the event stays credible	No
4 Mostly ineffective	Exists on paper or in part; rarely works as intended	No
5 None or ineffective	Absent, not yet in place, expired or not operating	No

Rate the control as it is today, not as it will be after the actions. A planned, draft or expired control is level 5. The middle column is a plain-language guide; the Risk team's definitions govern.

INPUT 4 OF 4

Evidence status: what you can show

Supported

Independent audit or test result, logs or configuration evidence dated within the last 12 months, showing the control operating as designed.

Example: a SOC 2 Type II report in hand, period within 12 months, scope covers the service.

Partially supported

Design evidence only (a policy, a contract clause, settings without operating evidence), or operating evidence older than 12 months.

Example: a signed clause requiring access reviews, but no review has run yet.

Not verified

A questionnaire answer or attestation only; planned, draft or expired controls.

Example: the business lead ticks “MFA” on the PIA form and nothing else is provided.

A questionnaire answer on its own is always Not verified. Ask for the evidence; if it does not arrive, record the gap as an action and score what you have.

PART 3 · READ

The credit table is the heart of the rule

Effectiveness	Supported	Partially supported	Not verified
1 Fully effective	2	1	0
2 Mostly effective	1	1	0
3 Partially effective	0	0	0
4 Mostly ineffective	0	0	0
5 None or ineffective	0	0	0

How to read it

The credit is the number of likelihood levels the control removes: 0, 1 or 2.

It is the lower of what the effectiveness earns and what the evidence earns. Strong control, weak evidence: little or no credit.

Four of the fifteen cells earn anything. That is the point: credit is for controls you can show are working.

The matrix turns impact and likelihood into a band

Impact \ Likelihood	Rare	Unlikely	Possible	Likely	Almost certain
5 Extreme	High	High	High	High	High
4 Major	Medium	Medium	Medium	High	High
3 Moderate	Low	Low	Medium	Medium	High
2 Minor	Low	Low	Low	Medium	Medium
1 Insignificant	Low	Low	Low	Low	Low

Used twice

Once with inherent impact and inherent likelihood, to get the inherent band.

Once more with the same impact and the residual likelihood (after credit), to get the residual band.

Read along the Major row: credit can move a risk from High to Medium, never to Low. That is the Highly Confidential floor at work.

What the workbook calculates, in seven steps

1 **Inherent band** = matrix of inherent impact and inherent likelihood.

2 **Modifier** moves the inherent band up one step, if the PIA has one.

3 **Pathway check:** the named control must be on the map for the risk category, or the credit is 0.

4 **Credit** = credit table of effectiveness and evidence: 0, 1 or 2.

5 **Residual likelihood** = inherent likelihood minus credit, never below Rare. Impact stays as scored.

6 **Residual band** = matrix of impact and residual likelihood; the modifier moves it up one step again.

7 **Cap:** the residual band can never be higher than the inherent band.

PIA **PIA rating** = the highest residual band across all risks. Never an average.

WORKED EXAMPLE 1 · CREDIT EARNED, NO MODIFIER

A vendor portal holding injury-claim files for 4,000 claimants

Inputs

- Data class: Highly Confidential (minimum Major)
- Modifier: None (4,000 people)
- Risk 5, unauthorized access or disclosure
- Impact 4 Major; likelihood 4 Likely
- Control: least-privilege access
- 2 Mostly effective; Supported (SOC 2 Type II, March 2026)

Step	Calculation	Result
1	Matrix: Major x Likely	High
2	No modifier	High (inherent)
3	Least-privilege access is on the map for risk 5	Yes
4	Credit table: Mostly effective, Supported	1
5	Likelihood 4 minus 1; impact stays Major	3 Possible
6	Matrix: Major x Possible; no modifier	Medium
7	Medium is not above High	Medium, ERM 3

Agreed action: quarterly access reviews, which would make the control Fully effective. Expected after actions: credit 2, likelihood Unlikely, Major x Unlikely is still Medium. The impact keeps this risk at Medium however good the control becomes.

WORKED EXAMPLE 2 · NO CREDIT, MODIFIER APPLIES

A payments vendor with no contract yet, 60,000 payees

Inputs

- Data class: Highly Confidential (bank details)
- Modifier: Scale (more than 10,000 people)
- Risk 12, vendor and sub-processor: processing outside instructions
- Impact 3 Moderate (loss of control, not exposure); likelihood 3 Possible
- Control: contractual processing restrictions
- 5 None (no agreement signed); Not verified

Step	Calculation	Result
1	Matrix: Moderate x Possible	Medium
2	Scale modifier: up one step	High (inherent)
3	Contract restrictions are on the map for risk 12	Yes
4	Credit table: None, Not verified	0
5	Likelihood 3 minus 0; impact stays Moderate	3 Possible
6	Matrix: Moderate x Possible, then modifier	High
7	High is not above High	High, ERM 4

Impact sits below the Major minimum, so the row is flagged and the rationale says why: the harm is loss of control, and exposure of the bank data is scored in another row. Expected after the agreement is signed (Fully effective, Supported): credit 2, Rare, Moderate x Rare is Low, modifier makes it Medium.

PART 4 · DECIDE

Reading the result: the PIA takes its highest risk

Residual	What it means	Who signs	Review
Low	Acceptable; proceed once gates are met	Privacy Analyst	On change, or every 36 months
Medium	Acceptable with Privacy Office recommendations	Privacy Analyst	On change, or 24 months
High	Acceptable with formal acceptance of actions by the Contract/System Owner, with Privacy concurrence	Manager, Privacy	On change, or 12 months

Highest, never average

One High risk makes the PIA High. Seven Lows do not dilute it.

Record both ratings

The current rating decides. The expected rating after actions is reported beside it, never instead of it.

High goes on the register

Every High rating and every accepted High risk is recorded in the privacy risk register and the quarterly ERM report.

Six mistakes that break reproducibility

Do not	Do instead
Give credit for a planned, draft, expired or self-attested control	Score it as it is today (level 5 or Not verified); put the fix in the actions and let the expected rating show the gain
Score likelihood with the controls already in mind	Score the raw exposure first; the controls earn their credit in inputs 3 and 4
Score the same gap in several rows	Name one row that carries it; the other rationales point to that row
Average the risks to get the PIA rating	The PIA rating is the highest residual band, always
Lower the impact because a control limits the harm	Impact stays as scored; a reduction is a Chief Privacy Officer exception, written in the rationale and the register
Type over a calculated cell to get the band you expected	Change an input you can defend, or raise the rationale with the Privacy Office; grey cells are never edited

Before you submit

- Every risk statement names a cause, an event, the people affected and a harm
- Facts are separated from assumptions, and each assumption is written down
- Every control named is on the pathway map for its risk (column K says Yes)
- Every Supported or Partially supported status has an evidence reference with a date
- Every row flagged below the data-class minimum says in its rationale why the harm is not exposure
- Conflicts between the questionnaires are listed, with the higher credible reading used
- Open gates are named in the summary, and the TPRM rating is within one band or explained
- Every action has an owner and a due date, and no grey cell has been typed over

Where to find things

The workbook

- Read me: the rule in brief
- Assessment: the blank template
- Claims EFT (4-input): a completed example
- Pathway map: which controls count for which risk
- Lookups: the matrix, credit table and decision table

The documents

- Privacy Residual Risk Decision Rule (one page): the rule itself
- Privacy Risk Assessment Methodology: scales, matrix, modifiers, approvals
- Privacy risk catalogue and control catalogue

When to ask

- A control you rely on is not on the map for its risk
- You think impact should be reduced by a control
- The two questionnaires conflict and neither reading is clearly more credible
- A calculated band looks wrong to you

Ask the Privacy Office. Never change the map, the credit table or a grey cell yourself.